

AMENAZAS PERSISTENTES AVANZADAS.



¿QUÉ, QUIÉN, CÓMO, CUÁNDO, DÓNDE Y POR QUÉ?

¿QUÉ ES UN APT?

Las Amenazas Persistentes Avanzadas, Advanced Persistent Threat o APT, son procesos informáticos maliciosos que como su propio nombre indica:

- Representan una **amenaza** debido a que tienen objetivos muy concretos, normalmente robo de información clasificada o vital, ganancia financiera o sabotaje a gran escala.
- Estamos hablando de un malware **persistente** que está diseñado expresamente para permanecer oculto en el sistema. Además, no provoca sospechas de su instalación, escondiendo sus comunicaciones al exterior mediante un fuerte cifrado y enviando pequeños paquetes de datos en intervalos. Es así como va a intentar permanecer el mayor tiempo posible en la red víctima. Al acabar el trabajo intentará desinstalarse eliminando registros y otros rastros que pudieran delatar su procedencia, forma de entrar, trabajo realizado o cualquier otra información sobre él.
- Por último, estos procesos usan técnicas **avanzadas** como canales de comunicación cifrados, vulnerabilidades de día cero (0-Days) o sofisticadas capacidades de evasión y propagación para superar las defensas de la red y poder infectar a más sistemas.

Además de hacer referencia a los procesos maliciosos, las siglas APT también se refieren al tipo de ataque y al grupo que se encuentra detrás de este malware. Más adelante hablaremos de ello.

¿QUIÉN ESTÁ DETRÁS DE UNA AMENAZA PERSISTENTE AVANZADA?

Desgraciadamente, esta es una pregunta con difícil respuesta, ya que no se puede saber a ciencia cierta quién está detrás de una amenaza a esta escala. Tan solo se puede analizar lo que se encuentre de la amenaza e inferir qué puede estar pasando o quién puede haberla creado. Por ello no se habla de creadores sino que se denominan “atribuciones”.

Los analistas especializados en malware de un equipo, como puede ser un CERT o empresas de antivirus, le dan un nombre tanto a la amenaza como al grupo, por lo general con nombre “propio” como Turla o Carnabak, aunque también podemos encontrarlos como APTXX, siendo la XX un número.

Se sabe que estos grupos tienen unos recursos humanos, económicos y materiales considerables, dado que sin estos no podrían lograr todo lo que consiguen con su malware. No obstante, la financiación con la que cuentan tiene una fuente desconocida porque nadie ha reclamado su participación en las acciones.

Por lo general se atribuye la procedencia del grupo según la información que puede extraerse del malware, como el idioma de los comentarios del código o las formas de actuar que se han podido ver anteriormente en otros APT que ya tenían atribución.

¿Significa eso que puede asegurarse con certeza que un estado/empresa/organización con suficiente capital económico, humano y tecnológico puede estar detrás de un grupo APT y de sus acciones?

Rotundamente no, por lo dicho anteriormente. Nadie ha desmentido estar involucrado o no en las acciones de estos grupos.

Como ejemplo se puede tomar un fragmento de programa que esté escrito en chino.

¿Tiene China un poder financiero, humano y tecnológico suficiente como para desarrollar un software de este calibre? Si.

¿Tiene una empresa china ese poder? Probablemente.

¿Puede hacer esto un señor que viva en Villanueva de la Cañada que sepa chino? En el caso que ese señor tenga ese tipo de recursos es bastante posible que pueda hacerlo.

¿Puede ser otro estado/empresa/organización que esté haciendo un ataque de bandera falsa para inculpar a otro estado/empresa/organización? También es un caso bastante probable.

Pero al finalizar, no se tiene la certeza de quien ha hecho el ataque porque no se tienen las suficientes pruebas. Lo único que queda es atribuir una posible procedencia que no es determinante.

Por lo general, y siempre según atribuciones, estos grupos suelen tener a algún estado apoyándoles. Por ejemplo en el caso de TAO, que supuestamente está apoyado por EEUU según revelaciones de Edward Snowden; APT1 que tiene relación con la unidad 61398 del Ejército Popular de Liberación de China según el informe de Mandiant (Ahora FireEye); o APT28 y APT29 que se intuye que podría estar relacionada con las unidades 26165 y 74455 del GRU, la inteligencia Rusa según F-Secure.

¿CÓMO “TRABAJA” UN APT?

Generalmente se utilizan ataques de día cero (0-day). Estos se aprovechan de vulnerabilidades para los que no hay un parche de seguridad apropiado, ya sea por tratarse de una vulnerabilidad desconocida, o porque aún no se haya desarrollado dicho parche.

Por otra parte, podemos destacar los ataques de abrevadero (watering hole), que consisten en atacar webs de terceros muy utilizadas, como por ejemplo las redes sociales. El foco principal de estos ataques son los usuarios de la organización objetivo, que al acceder a esas páginas web, se descargan la amenaza ellos mismos sin percatarse.

¿CUÁNDO ATACA?

Según diversos análisis, algunos malware “empiezan” y “terminan” de trabajar en una franja horaria determinada. Esto puede aportar una pista más de su posible procedencia, aunque por lo general cualquiera puede infectarse en cualquier momento del día y en cualquier lugar, dado la naturaleza del artefacto.

¿DÓNDE SE PUEDE ENCONTRAR UN APT?

Lamentablemente no se puede marcar un patrón de sistemas en los que pueda instalarse un APT o no, por ejemplo, se han encontrado casos en dispositivos IoT, routers, sistemas de centrales nucleares, ordenadores normales e incluso smartphones.

Todo el mundo puede ser objetivo de un grupo APT si este último encuentra suficiente interés. Sin embargo, los principales focos son entidades con un alto poder financiero o que sean vitales para un estado (por ejemplo, centrales nucleares, suministro de agua y electricidad, etc.)

¿POR QUÉ LOS HACEN?

Las razones más frecuentes por las que estos grupos programan y distribuyen las amenazas persistentes avanzadas son las siguientes:

- Provocar una distracción al hacer un ataque de falsa bandera y poder desacreditar a una organización rival.
- Sabotaje de infraestructuras críticas para provocar desestabilidad en otras entidades.
- Extracción de datos para futuras acciones.
- Interés financiero, etc.

Es decir, cualquier fin que le permita al grupo (y por ende a la organización que le apoya) una ventaja económica, política o estratégica puede ser una razón válida.

Si se quiere profundizar en alguno de los grupos o ataques APT, se puede consultar la información que ThaiCERT tiene al respecto. En esta, destaca la predominancia de grupos de atribución Rusa y China. A continuación le siguen en cantidad grupos asiáticos de atribución Iraní o India, además de Corea del Norte, Corea del Sur o Turquía. Siguiendo con Estados Unidos para acabar con la baja participación del continente europeo en la escala con casos atribuidos a Ucrania, Rumanía o Francia y LATAM con Brasil y México. De momento no se ha atribuido origen español a ningún APT.

Sin nada más que añadir, espero que este artículo sirva como introducción al mundo del ciberespionaje y las amenazas persistentes avanzadas.

BIBLIOGRAFÍA

- Comment Crew o APT1: https://web.archive.org/web/20130219155150/http://intelreport.mandiant.com/Mandiant_APT1_Report.pdf
- Fancy Bear o APT28: <https://www.fireeye.com/content/dam/fireeye-www/global/en/current-threats/pdfs/rpt-apt28.pdf>
- Cozy Bear o APT29: https://blog-assets.f-secure.com/wp-content/uploads/2020/03/18122307/F-Secure_Dukes_Whitepaper.pdf
- TAO: <https://www.spiegel.de/international/world/the-nsa-uses-powerful-toolbox-in-effort-to-spy-on-global-networks-a-940969.html>
- Ataque de Abrevadero: https://es.wikipedia.org/wiki/Ataque_de_abrevadero
- 0-Day: https://es.wikipedia.org/wiki/Ataque_de_d%C3%ADa_cero
- IoT APT: https://www.researchgate.net/publication/335611873_Advanced_Persistent_Threats_Through_Industrial_IoT_On_Oil_And_Gas_Industry
- Routers APT : <https://symantec-enterprise-blogs.security.com/blogs/threat-intelligence/inception-framework-hiding-behind-proxies>
- Central Nuclear APT: <https://www.cyberbit.com/blog/endpoint-security/dtrack-apt-malware-found-in-nuclear-power-plant/>

- Smartphones
APT: <https://www.sciencedirect.com/science/article/pii/S187705091732971X>
- ThaiCERT: <https://www.thaicert.or.th/>

Iván Carlo Alcañiz Bautista